

Reporte de Seguridad — Cantera Digital

Fecha: 23 de mayo 2026 | **Para:** Dirección General | **Estado:** Intervención completada

¿Qué pasó?

Se realizó una auditoría de seguridad a la infraestructura tecnológica de Cantera Digital. Se encontraron vulnerabilidades graves que dejaban la base de datos de la empresa completamente expuesta a internet — cualquier persona con conocimiento básico de tecnología podía acceder, leer, modificar o borrar toda la información sin necesidad de usuario ni contraseña.

Ese mismo día se corrigieron todos los problemas críticos. Los sistemas siguen funcionando con normalidad para los usuarios.

¿Qué información estaba en riesgo?

- **Datos de empleados:** nombre, CURP, RFC, número de seguro social, dirección, fecha de nacimiento, estado civil, tipo de contrato.
 - **Datos de candidatos de RH:** información de salud (diabetes, hipertensión, discapacidad, medicamentos controlados), historial laboral, datos personales completos.
 - **Datos de clientes:** conversaciones de WhatsApp, información de contacto, historial de pagos, suscripciones.
 - **Claves de acceso** a los sistemas de automatización de la empresa.
-

¿Qué tan grave era?

Para entenderlo sin términos técnicos: era equivalente a dejar la puerta de la oficina abierta de par en par, con todos los expedientes en la entrada y un letrero que decía la clave de la caja fuerte.

Los problemas encontrados eran:

1. **La base de datos estaba conectada directamente a internet**, como si el servidor de archivos de la empresa tuviera una entrada pública. Cualquier persona podía conectarse desde cualquier parte del mundo.
2. **La contraseña del servidor de base de datos era la que viene por defecto** en el manual del programa — conocida públicamente y documentada en internet.

- 3. Los sistemas de seguridad internos estaban desactivados.** La base de datos tiene un sistema de control de acceso por tabla (equivalente a tener carpetas con llave dentro de la oficina). Las 67 carpetas estaban sin llave.
- 4. El firewall del servidor estaba apagado.** El firewall es el equivalente al guardia de seguridad en la puerta del edificio — estaba instalado pero no estaba trabajando.
- 5. El sistema de claves maestras estaba comprometido.** Con la clave maestra que usaba el sistema, cualquier persona podía fabricar credenciales de administrador sin necesidad de robarlas.
-

¿Qué se hizo?

Todo se corrigió el mismo día:

- ✔ Se desconectó la base de datos de internet — ahora solo es accesible internamente.
 - ✔ Se cambiaron todas las contraseñas y claves del sistema.
 - ✔ Se activó el firewall con políticas estrictas.
 - ✔ Se activó el sistema de control de acceso en 59 de 67 tablas.
 - ✔ Los sistemas de automatización (chatbots, leads) se actualizaron con las nuevas credenciales.
 - ✔ Todos los portales y aplicaciones de los clientes siguen funcionando con normalidad.
-

¿Qué falta por hacer?

Tarea	Por qué importa	Tiempo estimado
Proteger las 8 tablas restantes	Completar el 100% de la base protegida	15 minutos
Corregir bug de borrado de leads	El borrado de leads nunca funciona — falla sin avisar al usuario	15 minutos
RespalDOS automáticos diarios	Hoy los respaldos son manuales — un fallo podría significar pérdida total de datos	1.5 horas
Proteger el servidor contra ataques externos	Ya hubo ataques previos (DDoS, caída de servidores)	2.5 horas

Tarea	Por qué importa	Tiempo estimado
Actualizar el sistema de login	El sistema de acceso actual tiene limitaciones de seguridad que conviene modernizar	4 días
Revisar una base de datos secundaria con credenciales antiguas	Se encontró una base de datos de versiones anteriores con accesos que deben limpiarse	5 horas

Las tareas del primer punto se pueden completar en **un solo día de trabajo**. La modernización del sistema de login requiere los **4 días restantes**.

Tiempo total restante estimado: 5 días hábiles con el equipo de dos desarrolladores.

Este estimado contempla el uso de herramientas de asistencia de IA (Claude y Claude Code) que reducen significativamente el tiempo de desarrollo, y un margen del 20% para imprevistos.

Nota legal importante

Durante la auditoría se determinó que la base de datos estuvo expuesta durante un tiempo no determinado. Dado que contiene datos personales sensibles de empleados (CURP, NSS, datos de salud de candidatos), la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) puede contemplar obligaciones de notificación.

Se recomienda consultar con un abogado especialista en protección de datos para determinar si existe alguna obligación legal de notificación al INAI o a los titulares de los datos, y actuar en consecuencia.

Resumen en números

	Antes	Hoy
Problemas críticos activos	6	0
Tablas de datos protegidas	0 de 67	59 de 67
Firewall activo	No	Sí
Contraseñas seguras	No	Sí

